By TOUCH DEN · November 11, 2026

Security Frameworks and Standards



Video 1 · Frameworks, NIST CSF, and CIS

Security Fundamentals · Section 10

In this video, you will learn:

- Why frameworks exist
- The NIST Cybersecurity Framework's six functions
- The CIS Critical Security Controls

Why frameworks exist

A security program has dozens of parts. Invent it alone and you'll miss something. ***Frameworks*** *are published, expert-built guidance on what to do.*

They give you:

- ***Completeness:*** *a checklist so you don't forget whole areas.*
- ***A common language:*** *your team, auditors, and partners agree on terms.*
- ***Credibility:*** *shows customers and regulators you're serious.*
- ***A starting point:*** *adapt proven guidance, don't start from blank.*

You don't use all of them, they serve different purposes.

NIST CSF 2.0: six functions

A free, widely-used structure for a whole program.

Function	The question
Govern	Who's responsible; what are our risks and policies?
Identify	What do we have, and what matters?
Protect	How do we safeguard it?
Detect	How do we notice something happened?
Respond	What do we do during an incident?
Recover	How do we return to normal?

Govern was added in 2.0 (2024): security is a leadership job. Ask "how are they doing on each of the six?"

CIS Critical Security Controls

*NIST says what areas; **CIS** gives a **prioritized list of what to actually do**, most effective first.*

Early, high-impact controls:

- *Know your hardware and software.*
- *Control accounts and access; use **MFA**.*
- *Manage vulnerabilities (patching).*
- *Keep and monitor logs; train staff.*
- *Backup and recovery.*

***Implementation Groups** (IG1–IG3) size it: a small shop does **IG1** and blocks most common attacks.*

Recap: frameworks, NIST, CIS

- *Frameworks give completeness, a common language, credibility, and a starting point.*
- ***NIST CSF** structures a whole program in six functions (Govern, Identify, Protect, Detect, Respond, Recover).*
- ***CIS Controls** tell you what to do first; IG1 suits a small business.*

***Next video:** ISO 27001, MITRE ATT&CK, and the compliance trap.*

Security Frameworks and Standards



Video 2 · ISO 27001, MITRE ATT&CK, and Compliance

Security Fundamentals · Section 10

In this video, you will learn:

- ISO/IEC 27001, the international standard
- MITRE ATT&CK, the attacker knowledge base
- Compliance vs. real security

ISO/IEC 27001

*The leading **international standard** you can be **certified** against: an independent auditor checks your security management.*

- *Central idea: an **ISMS**, an ongoing, documented process for managing security by risk, not a product.*
- ***ISO 27002** is its catalogue of controls.*
- *Many big customers and contracts **require** suppliers to be certified.*

More formal and more effort than CIS, usually a goal for a maturing organization, not a first step.

MITRE ATT&CK

*Not a program framework, a **knowledge base of how attackers actually behave**, by attack stage.*

- *For each stage, the **techniques** real attackers use, with examples and **how to detect and defend**.*
- *Built from observing real attacks.*

Why it's valuable:

- *A **common language** for attacker behavior.*
- *Defenders **measure coverage**: what can we detect; where are the blind spots?*

Used heavily in the defensive and red-team courses.

Compliance vs. security

One of the most important distinctions in the field.

- ***Compliance:*** *meeting formal requirements, passing an audit.*
- ***Security:*** *actually being hard to attack.*

They overlap but aren't the same:

- ***Compliant but insecure:*** *every box ticked, controls weak in practice. Many breached firms were certified.*
- ***Secure but not yet compliant:*** *great habits, no paperwork.*

> ***Compliance is a floor, not a ceiling.***

Recap: standards and compliance

- ***ISO 27001:*** *a certifiable standard built on an ISMS; needed to sell to big customers.*
- ***MITRE ATT&CK:*** *the shared map of attacker techniques, for detection and defense.*
- ***Compliance is a floor, not a ceiling****, build real security on top.*
- *Sensible combo: NIST to organize, CIS to prioritize, ATT&CK for detection, ISO later.*

Next lesson: *the people who do this work, security roles and the industry.*